

////// HIPAA



**Health Insurance Portability &
Accountability Act**

PRIVACY RULE

SECURITY RULE

**Breach
Notification**

**Enforcement
Rule**





WHAT IS HIPAA?

HIPAA is a U.S. federal law that protects patients' private health information.

Any organization that handles medical records, insurance information, or health-related data must follow HIPAA or face significant penalties.

WHO MUST COMPLY?

Hospitals & Clinics	Pharmacies
Dental Offices	Health Insurers
Healthcare IT Vendors	Labs & Testing Centers

The 4 HIPAA RULES

Privacy Rule

Controls who can view and use patient information

Security Rule

Requires administrative, physical, and technical safeguards for electronic records

Breach Notification Rule

Requires notifying patients within 60 days after a breach

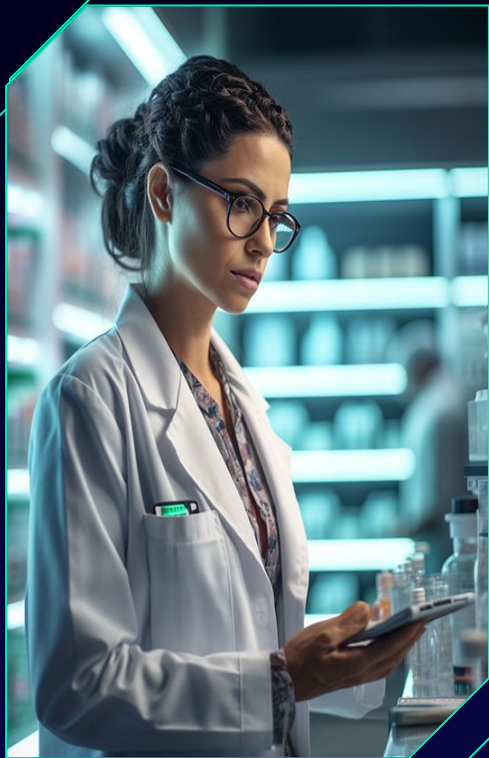
Enforcement Rule

Establishes fines up to \$1.9M per violation category per year

PROJECT SCENARIO – BLUE STAR MEDICAL CLINIC

You are a cybersecurity analyst
hired by Blue Star Medical Clinic.
They store 1,200 patient health
records digitally.
Your job is to evaluate HIPAA
compliance and build a
remediation plan.





What the Clinic Has

Electronic Health Record (EHR) software

Cloud storage for patient files (Google Drive)

50 employees with access to various systems

Basic username/password logins

Paper sign-in sheets at reception

No formal security policies

HIPAA Gaps Identified

No Multifactor Authentication (MFA)

Patient data not encrypted at rest

No formal HIPAA training for employees

Missing Business Associate Agreements (BAAs)

No documented incident-response plan

Audit logs not being reviewed



HIPAA PRIVACY RULE

CONTROLS WHO CAN ACCESS AND USE PROTECTED HEALTH INFORMATION (PHI)



WHAT IS PHI? - Protected health information is any information that can identify a patient named date of birth diagnosis insurance ID address phone number photos or any combination of these.

Minimum Necessary Rule	Patient Rights	Permitted disclosures
Share the minimum info details	Patience can request their own records	Can share with treating providers
Receptionist doesn't need diagnosis details	Patients can request corrections	Can share for billing purposes
Billing only sees payment info	Patience can restrict who sees their info	Can share for public health reporting
Apply to all staff and vendors	Must respond within 30 days	Never share for marketing without consent



HIPAA Privacy Rule

REQUIRES 3 TYPES OF SAFEGUARDS TO PROTECT ELECTRONIC (ePHI)



WHAT IS PHI? - Protected health information is any information that can identify a patient named , date of birth diagnosis insurance ID address phone number photos or any combination of these.

ADMINISTRATIVE SAFEGUARDS	PHYSICAL SAFEGUARDS	TECHNICAL SAFEGUARDS
RISK ANALYSIS Conduct a written risk assessment identify every threat to ePHI.	FACILITY ACCESS CONTROLS Locked server rooms, keycards access, visitor logs.	ACCESS CONTROLS Unique user IDs, MFA, auto-logout after after 15 min idle.
WORKFORCE TRAINING Train ALL employees on HIPAA annually, Document it.	WORKSTATION SECURITY Screen locks, privacy screen, no unattended sessions.	AUDIT CONTROLS Log all access to patient records who, when, what.
ACCESS MANAGEMENT Formal process for granting and revoking system access.	DEVICE CONTROLS Policy for laptops, USB drives, and mobile.	ENCRYPTION Encrypt ePHI at rest (AES-256) and in transit (TLS 1.2+)
CONTINGENCY PLAN Written for data backup and disaster recovery	DISPOSAL POLICY Shred paper records, wipe drives before disposing of hardware.	INTEGRITY CONTROLS Verify data hasn't altered use checksum/hashing.



HIPAA BREACH NOTIFICATION RULE

Scenario: The ransom attack encrypted 800 patient records here exactly what HIPAA requires.



PATIENTS

WITHIN 60 DAYS Send written notification by first class mail or email if they opt in must include what happened what PHI was involved what you're doing about it and a toll free number to call.



MEDIA (If 500 = in a state)

WITHIN 60 DAYS If 500 or more residents of a single state are affected notify a major media outlet in the state (e.g. Local TV news station or newspaper)



HHS/Federal Gov.

WITHIN 60 DAYS Submit a bridge report to the HHS office for civil rights at [HHS.gov](https://www.hhs.gov) breach of 500+ must be reported immediately. Under 500 can be logged in reported annually.



Business Associates

WITHIN 60 DAYS If a vendor causes the breach they must notify you within 60 days your Business Associate Agreement (BAA) should require this. Without a BAA you are still liable.



Criminal penalties: Intentional misuse of PHI = up to 10 years in federal prison + \$250,000

HIPAA ENFORCEMENT & PENALTIES

FINES AND PENALTIES

TIER 1

DON'T KNOW

\$100 - \$50,000

PER VIOLATION

MAX \$25,000/year

You violated HIPAA but had no way of knowing still a fine ignorance doesn't protect you.

TIER 2

REASONABLE CAUSE

\$1,000-\$50,000

PER VIOLATION

MAX \$1000,000/year

You should have known about the violation but weren't being deliberately negligent.

TIER 3

WILLFUL NEGLECT (FIXED)

PER VIOLATION

MAX \$250,000/year

You knew you were violating HIPAA and fix it within 30 days of discovery.

TIER 4

WILLFUL NEGLECT (NOT FIXED)

\$50,000+

PER VIOLATION

MAX \$1.9M

You knew violet intentionally and did not correct it maximum penalties apply.

HIPAA COMPLIANCE CHECKLIST - ELITE STAR MEDICAL CLINIC

 Conduct a formal written Risk Analysis SECURITY RULE	 Enable MFA on all staff and admin accounts. SECURITY RULE
 Encrypt all e PHI at rest (AES-256) and transit (TLS 1.2+) SECURITY RULE	 Sign business associate agreements (BAAs) with all vendors PRIVACY RULE
 Train all 50 employee on HIPAA - Document completion ADMIN SAFEGUARD	 Implement audit logging on all systems that access PHI SECURITY RULE
 Create and test a data Backup & Recovery Plan ADMIN SAFEGUARD	 Post a Notice of Privacy Practices (NPP) in the clinic PRIVACY RULE
 Lock server room with keycard access and visitor log PHYSICAL SAFEGUARD	 Set workstations to auto-lock after 15 minutes idle TECHNICAL SAFEGUARD



PROJECT SUMMARY



HIPAA

PRIVACY RULE Define PHI, minimum necessary access, patient rights.	SECURITY RULE Applied all 3 safeguards: Administrative, Physical & Technical.	BREACH NOTIFICATION Built a 4-party notification plan with 60-day deadlines.
ENFORCEMENT Document fine tiers from \$100 to \$1.9M per violation.	COMPLIANCE CHECKLIST Create a 10-item remediation checklist for the clinic.	RISK ANALYSIS Identified 6 critical HIPAA gaps in the organization.

